

Security+ 5.1 · Security Procedures

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 5.1** — Security Procedures (7:02) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Operational security procedures cover the full employee lifecycle and common security workflows. Onboarding creates accounts and grants access; offboarding disables accounts, revokes access, and collects equipment. Failure to complete offboarding creates orphan accounts. Other key procedures include phishing response and password reset.

High-Yield Core Concepts Tested on Exam

- Offboarding: disable account, revoke access, collect equipment — missed steps create orphan accounts
- Orphan account = account with no owner after failed offboarding — high risk
- Onboarding: create account and provision access based on role
- Phishing response procedure: report, isolate, analyze, remediate
- Password reset procedure: verify identity, enforce policy, log event

Exam Tips & Classic Scenarios

- 'process when employee leaves the company' = offboarding
- 'account still active after employee departure' = orphan account (offboarding failure)

Typical Exam Scenario: An employee leaves the company but their account remains active and accessible. This is an orphan account caused by failed offboarding. The exam may ask you to identify the missing procedure or the risk.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 5.1 — Security Procedures)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. The NIST CSF framework organizes security into 5 functions. What are they?

- A)** Install, Update, Test, Audit, Archive
- B)** Identify, Protect, Detect, Respond, Recover
- C)** Plan, Do, Check, Act, Review
- D)** Prevent, Punish, Predict, Prove, Publish

2. Giving each user ONLY the minimum access they need for their role is:

- A)** Least privilege
- B)** Separation of duties
- C)** Job rotation
- D)** Geographic need-to-know

3. Corporate scenario (Security Procedures): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.1), an analyst evaluates the following technical requirement: 'Offboarding: deactivate account, revoke access — the forgotten one creates ORPHAN'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Offboarding: deactivate account, revoke access — the forgotten one creates ORPHAN...
- D)** Allow shared access among administrators using generic credentials

4. Corporate scenario (Security Procedures): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.1), an analyst evaluates the following technical requirement: 'Orphan account = account without an owner after failed offboarding — high risk.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: Orphan account = account without an owner after failed offboarding — high risk...

5. Corporate scenario (Security Procedures): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.1), an analyst evaluates the following technical requirement: 'process when employee leaves the company' = offboarding. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'process when employee leaves the company' = offboarding...
- D)** Allow shared access among administrators with generic credentials

6. Corporate scenario (Security Procedures): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.1), an analyst evaluates the following technical requirement: 'employee left but account still active'=orphan account (offboarding failed)'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'employee left but account still active'=orphan account (offboarding failed)...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

7. Corporate scenario (Security Procedures): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.1), an analyst evaluates the following technical requirement: 'Offboarding: deactivate account, revoke access — the forgotten one creates an ORPHAN.' What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Offboarding: deactivate account, revoke access — the forgotten one creates an ORPHAN...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

8. Corporate scenario (Security Procedures): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.1), an analyst evaluates the following technical requirement: 'Orphan account = account without an owner after failed offboarding — high risk'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Orphan account = account without an owner after failed offboarding — high risk.
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Security Procedures): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.1), an analyst evaluates the following technical requirement: 'process when employee leaves the company'=offboarding'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'process when employee leaves the company'=offboarding...
- D)** Allow shared access among administrators using generic credentials

10. Corporate scenario (Security Procedures): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.1), an analyst evaluates the following technical requirement: 'employee left but account still active'=orphan account (offboarding failed)'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'employee left but account still active'=orphan account (offboarding failed)...
- D)** Allow shared access among administrators with generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — Identify, Protect, Detect, Respond, Recover.

✓ **Why it's correct:** The NIST Cybersecurity Framework (CSF) 2.0 organizes cybersecurity activities into five core functions: Identify, Protect, Detect, Respond, and Recover. These functions represent the complete lifecycle of cyber risk management. 'Identify' involves understanding the organizational context, assets, risks, and vulnerabilities. 'Protect' covers implementing safeguards to ensure delivery of critical services. 'Detect' defines activities to identify the occurrence of cybersecurity events. 'Respond' comprises actions taken after an incident is detected. 'Recover' focuses on restoring capabilities or services that were impaired. This framework is widely adopted and required in the Security Architecture and Design domain of the CompTIA Security+ (SY0-701) certification, specifically in objective 2.1, which deals with frameworks and guidelines.

✗ **Why the others are wrong:**

- *Install, Update, Test, Audit, Archive:* These terms describe generic steps of an IT operational process, such as a software lifecycle or patch management, but they do not constitute the NIST CSF functions. 'Install' and 'Update' refer to system deployment and maintenance; 'Test' is a verification activity; 'Audit' is a compliance assessment; and 'Archive' is a data retention practice. None of these actions correspond to the high-level strategic functions defined by the NIST CSF, which are risk-oriented rather than tactical tasks.
- *Plan, Do, Check, Act, Review:* This is a variation of the PDCA cycle (Plan-Do-Check-Act), used in quality management and continuous improvement systems, such as ISO 9001. Although the NIST CSF can be integrated into continuous improvement processes, its five functions are not 'Plan, Do, Check, Act, Review'. PDCA is a generic management model, while CSF functions are specific to cybersecurity and have their own scope and definitions. The inclusion of 'Review' as a fifth step is a distortion, as the classic PDCA has four steps.
- *Prevent, Punish, Predict, Prove, Publish:* These terms are not part of any recognized cybersecurity framework. 'Prevent' is a goal, but not a CSF function; 'Punish' is a disciplinary or legal action, not a security function; 'Predict' is an aspirational goal, not an operational function; 'Prove' and 'Publish' are audit and communication actions, respectively, but they do not compose the NIST CSF structure. This alternative mixes concepts of justice, prediction, and disclosure, with no relation to the official functions of the framework.

2) A — Least privilege.

✓ **Why it is correct:** The correct answer is 'Least privilege'. The principle of least privilege determines that each user, process, or system should be granted only the permissions strictly necessary to perform its functions, and nothing more. In the information security context, this reduces the attack surface and limits the impact of a compromise. For example, a user in the finance department should not have access to human resources files. CompTIA Security+ SY0-701, in the Architecture and Design domain (2.1), lists least privilege as a fundamental security principle. The question describes exactly this definition: giving each user only the minimum access they need for their role.

✗ **Why the others are wrong:**

- *Separation of duties:* Separation of duties is a control that divides a critical task into steps performed by different people, so that no single person has total control over the process. For example, the person who approves a payment cannot be the same person who executes it. This prevents fraud and errors, but it does not refer to granting minimum access per user; instead, it distributes responsibilities. The question is about individual minimum access, not task division.
- *Job rotation:* Job rotation is the practice of periodically moving employees between different

roles to detect fraud, reduce monotony, and train staff. It has no relation to the principle of granting only necessary access. Job rotation is an internal risk mitigation strategy, but it does not define each user's privilege level.

- *Geographic need-to-know*: Need-to-know is a security principle that restricts access to information only to those who need it to perform a specific task. However, 'geographic need-to-know' is not a standard term in the CompTIA Security+ certification. The concept of need-to-know is often associated with least privilege, but the expression 'geographic' adds a location restriction that is not present in the classic definition. The question does not mention geographic restriction, only functional minimum access. Therefore, the alternative is imprecise and does not correspond to the correct technical term.

3) C — Implement the corresponding solution: Offboarding: deactivate account, revoke access — the forgotten one creates ORPHAN....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.1 (Security Procedures): Offboarding: deactivate account, revoke access — the forgotten one creates ORPHAN.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

4) D — Implement the corresponding solution: Orphan account = account without an owner after failed offboarding — high risk....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.1 (Security Procedures): Orphan account = account without an owner after failed offboarding — high risk. Orphan accounts pose a significant threat because they retain access privileges without oversight, enabling attackers to use them for persistence and lateral movement.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

5) C — Implement the corresponding solution: 'process when employee leaves the company' = offboarding....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.1 (Security Procedures): 'process when employee leaves the company' = offboarding. Offboarding is the formal process of revoking access, recovering assets, and ensuring knowledge

transfer when an employee departs, reducing insider threat and unauthorized access risks.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) A — Implement the corresponding solution: 'employee left but account still active'=orphan account (offboarding failed)....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.1 (Security Procedures): 'employee left but account still active'=orphan account (offboarding failed).

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) A — Implement the corresponding solution: Offboarding: deactivate account, revoke access — the forgotten one creates an ORPHAN....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.1 (Security Procedures): Offboarding: deactivate account, revoke access — the forgotten one creates an ORPHAN. Proper offboarding procedures are critical to prevent orphan accounts, which can be exploited by attackers for unauthorized access and persistence.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

8) C — Implement the corresponding solution: Orphan account = account without an owner after failed offboarding — high risk..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for

lesson 5.1 (Security Procedures): Orphan account = account without an owner after failed offboarding — high risk. Orphan accounts pose a significant risk as they may be exploited by attackers; the appropriate control is to implement the corresponding solution, such as regular account reviews and automated deprovisioning.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

9) C — Implement the corresponding solution: 'process when employee leaves the company'=offboarding....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.1 (Security Procedures): 'process when employee leaves the company'=offboarding. Offboarding is the process of managing an employee's departure, including revoking access, returning assets, and ensuring knowledge transfer. The correct answer directly reflects this concept by recommending the implementation of the corresponding solution.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

10) C — Implement the corresponding solution: 'employee left but account still active'=orphan account (offboarding failed)....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.1 (Security Procedures): 'employee left but account still active'=orphan account (offboarding failed). Orphan accounts are a critical identity management risk because they retain access after the user no longer should have it, and must be identified and disabled through proper offboarding procedures.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual

accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.